FINAL SECURITY ASSESSMENT

1. Executive Summary

This report summarizes the findings of the academic application security lab demonstrating vulnerabilities common in modern web applications. The lab successfully simulated and remediated vulnerabilities like IDOR and Broken Authentication.

2. Objective

Build a local, self-contained educational lab demonstrating World Monitor-style vulnerabilities safely.

3. Scope

- Localhost vulnerable API (Port 3001)
- Localhost secure API (Port 3002)

4. Testing Environment

Local Windows environment using Node.js and Express. No external networks or production systems were targeted.

5. Findings

- **VULN-001**: Broken Authentication (High)
- **VULN-002**: Insecure Direct Object Reference (Medium)
- **VULN-003**: Missing Function-Level Authorization (Medium)
- **VULN-005**: Reflected XSS (Medium)
- **VULN-007**: Sensitive Data Exposure (Medium)

6. Remediation

All demonstrated vulnerabilities have been successfully remediated in the `secure-app` directory. Fixes include enforcing session checks, object ownership validation, role-based access control, and output encoding.

7. Conclusion

The laboratory effectively demonstrates the critical importance of server-side validation and authorization. (Controlled laboratory demonstration).